
Cuadernillo de Estudio — Clase 6

Seguridad Física: Perímetros, Controles y el Factor Humano

Seguridad Aplicada a Sistemas de Información
 Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
 Docente: Ing. Rodrigo Atilio Elgueta
 Ciclo Académico Vigente

Índice

1. Objetivos de aprendizaje	2
2. La Seguridad Física: La base olvidada	2
2.1. Amenazas a la seguridad física	2
3. El Modelo de Cebolla: Perímetros Concéntricos	2
4. Controles Ambientales e Infraestructura Crítica	3
4.1. Suministro de Energía	3
4.2. Climatización (HVAC)	3
4.3. Protección contra Incendios	3
4.4. Cableado Estructurado	4
5. El Eslabón más Débil: Ingeniería Social Física	4
5.1. Técnicas comunes de irrupción física	4
6. Glosario de conceptos clave	4
7. Autoevaluación	5
8. Respuestas de la Autoevaluación	5
9. Actividad A05: Desafío de Ingeniería Social	7
10. Fuentes y bibliografía	8
10.1. Bibliografía obligatoria (según programa)	8
10.2. Bibliografía complementaria (según programa)	8
10.3. Recursos web y normativas	8

1. Objetivos de aprendizaje

Al finalizar la lectura y el trabajo con este cuadernillo, el estudiante será capaz de:

- Comprender la **seguridad física** como la capa fundamental (Capa 0) de la Defensa en Profundidad.
- Diseñar modelos de **perímetros concéntricos** (modelo de cebolla) para la protección de activos críticos (Data Centers, salas de servidores).
- Analizar controles de acceso físicos, suministros de energía (UPS), climatización (HVAC) y protección contra incendios.
- Identificar técnicas de **Ingeniería Social** aplicadas a la irrupción de espacios físicos.
- Ejecutar la **Actividad A05** con estricto apego al marco ético y legal vigente.

Cómo usar este cuadernillo

En clases anteriores vimos firewalls y cifrado. Pero existe una máxima en la industria de la ciberseguridad: «*Si un atacante tiene acceso físico a tu servidor, deja de ser tu servidor*». Este cuadernillo te preparará para entender cómo proteger el hardware y cómo los atacantes usan la psicología humana para saltarse millones de dólares en seguridad lógica. Las respuestas de la autoevaluación están en la Sección 8.

2. La Seguridad Física: La base olvidada

La seguridad lógica (firewalls, antivirus, contraseñas) es inútil si un atacante puede entrar a la oficina, desconectar el servidor o robar el disco rígido. La seguridad física es el conjunto de medidas destinadas a proteger las instalaciones, el equipamiento y al personal contra amenazas físicas.

Seguridad Física

Conjunto de barreras, controles y procedimientos diseñados para prevenir el acceso no autorizado a instalaciones, proteger el equipamiento de daños (accidentales o intencionales) y garantizar la continuidad operativa del entorno físico.

2.1. Amenazas a la seguridad física

- **Naturales:** Inundaciones, terremotos, tormentas eléctricas, temperaturas extremas.
- **Accidentales:** Cortes de energía, incendios, fugas de agua, fallas en equipos de climatización.
- **Intencionales:** Robo de equipamiento, sabotaje, vandalismo, espionaje industrial, terrorismo.

3. El Modelo de Cebolla: Perímetros Concéntricos

La seguridad física se diseña en **capas superpuestas**, como una cebolla. Un atacante debe superar cada anillo para llegar al activo crítico (el servidor o el dato).

1. **Anillo 1 — Aproximación (La calle):** Iluminación perimetral, cámaras CCTV, cercos, rejas, barreras vehiculares, guardias de seguridad en la entrada.

2. **Anillo 2 — Terreno (El predio):** Control de acceso vehicular, patrullaje, detección de intrusos en ventanas.
3. **Anillo 3 — Edificio (La recepción):** Molinetes, mostrador de recepción, registro de visitas, entrega de credenciales temporarias.
4. **Anillo 4 — Piso / Sector:** Puertas con acceso biométrico o por tarjeta RFID, exclusión de visitantes no autorizados.
5. **Anillo 5 — Sala de Servidores / Data Center:** Puertas blindadas, control biométrico de doble factor, trampas (mantraps).
6. **Anillo 6 — Rack / Gabinete:** Cerraduras físicas en los racks, sensores de apertura de puertas.
7. **Anillo 7 — Activo:** Cifrado de disco, candados Kensington, sellos antimanipulación en los puertos USB.

4. Controles Ambientales e Infraestructura Crítica

Un Data Center no es solo un cuarto con computadoras. Requiere ingeniería especializada para garantizar la **Disponibilidad** (letra A de la Tríada CIA).

4.1. Suministro de Energía

Un corte de energía puede corromper bases de datos y dañar hardware. La cadena de protección típica es:

- **Red eléctrica pública:** La fuente primaria, sujeta a cortes.
- **UPS (Uninterruptible Power Supply):** Baterías que absorben microcortes y dan autonomía (minutos a horas) para un apagado controlado o el arranque de generadores.
- **Generadores diésel:** Entran en funcionamiento tras unos segundos para sostener la operación por días.

4.2. Climatización (HVAC)

Los servidores generan un calor inmenso. Si la temperatura sube, los equipos se apagan por protección térmica o sufren daños permanentes.

- Control estricto de temperatura (generalmente entre 18°C y 22°C).
- Control de humedad: el aire muy seco genera **electricidad estática** (que quema componentes); el aire muy húmedo genera condensación y cortocircuitos.
- Pisos técnicos elevados para distribución de aire frío y pasillos fríos/calientes.

4.3. Protección contra Incendios

¡El agua destruye los servidores!

En salas críticas, **no se usan rociadores de agua** (sprinklers), ya que apagar el fuego significaría destruir todo el hardware.

Se utilizan sistemas de **extinción por gases limpios** (como FM-200 o Novec 1230), que desplazan el oxígeno o absorben el calor para apagar el fuego en segundos, **sin dañar los equipos electrónicos** y sin ser tóxicos para las personas.

4.4. Cableado Estructurado

El cableado debe estar prolijamente identificado, en bandejas separadas del cableado eléctrico (para evitar interferencias electromagnéticas) y con etiquetas en ambos extremos. El desorden físico es un riesgo de seguridad y de disponibilidad.

5. El Eslabón más Débil: Ingeniería Social Física

La ingeniería social es el arte de manipular a las personas para que revelen información confidencial o realicen acciones que comprometen la seguridad. En el ámbito físico, se aprovecha de la confianza, la cortesía y la distracción.

5.1. Técnicas comunes de irrupción física

Tailgating (Pisar los talones)

El atacante sigue de cerca a un empleado autorizado que abre una puerta con su tarjeta, colándose antes de que la puerta se cierre.

Piggybacking (Llevar a cuestas)

Similar al tailgating, pero con **consentimiento** de la víctima. El atacante pide por favor que le sostengan la puerta porque «olvidó su credencial» o trae las manos ocupadas con cajas.

Dumpster Diving (Buceo en la basura)

Revisar los desechos de la empresa en busca de información valiosa: documentos impresos sin triturar, notas adhesivas con contraseñas, discos duros desechados sin borrar, organigramas.

Shoulder Surfing (Mirar por encima del hombro)

Observar la pantalla de un empleado o el teclado mientras ingresa su contraseña en un lugar público o en la oficina.

Suplantación de Identidad (Pretexting)

El atacante se disfraza de técnico de internet, personal de mantenimiento, bombero o inspector de seguridad e higiene para ganar acceso irrestricto a las instalaciones.

La cortesía como vulnerabilidad

Los seres humanos estamos programados socialmente para ser amables y ayudar. Un atacante que lleva una caja pesada y pide que le abran la puerta de un área restringida explotará tu instinto de cortesía. En seguridad física, la cortesía mal entendida es una vulnerabilidad crítica.

6. Glosario de conceptos clave

Perímetro

Límite físico o lógico que separa una zona segura de una no segura.

Mantrap	Esclusa de seguridad: una cabina pequeña con dos puertas. La segunda no se abre hasta que la primera se cierra y se valida la identidad.
HVAC	<i>Heating, Ventilation, and Air Conditioning</i> . Sistema de climatización crítico para Data Centers.
UPS	Sistema de alimentación ininterrumpida.
Tailgating	Ingreso no autorizado aprovechando la apertura de puerta de un tercero.
Piggybacking	Ingreso con complicidad (voluntaria o engañada) de un tercero.
Dumpster Diving	Búsqueda de información sensible en la basura.
Biometría	Autenticación basada en rasgos físicos (huella, iris, rostro, vena).
CCTV	Circuito cerrado de televisión para videovigilancia.

7. Autoevaluación

Respondé por escrito; luego verificá en la Sección 8.

1. ¿Por qué se afirma que «si un atacante tiene acceso físico ilimitado a un servidor, la seguridad lógica es irrelevante»? Mencioná al menos dos ataques físicos posibles.
2. Describí el concepto de **modelo de cebolla** aplicado a la seguridad de un Data Center y mencioná al menos 3 anillos de protección.
3. ¿Por qué en un Data Center no se utilizan rociadores de agua (sprinklers) tradicionales para apagar incendios? ¿Qué alternativa se usa y por qué?
4. Diferenciá **Tailgating** de **Piggybacking**. ¿Cuál de los dos es más difícil de mitigar con tecnología y por qué?
5. ¿Qué es el **Dumpster Diving** y qué política administrativa es fundamental para mitigarlo en una oficina?

8. Respuestas de la Autoevaluación

Nota para el estudiante

Utilizá estas respuestas para autoevaluarte. Son de referencia; en clase y en las actividades se valorará tu capacidad de argumentar y dar ejemplos propios.

Pregunta 1: Acceso físico vs. Seguridad lógica

Respuesta

Porque con acceso físico ilimitado, un atacante puede eludir las defensas lógicas actuando directamente sobre el hardware o el medio ambiente. Ejemplos de ataques físicos:

- **Robo del disco rígido:** Puede extraerlo e intentar romper el cifrado en un laboratorio offline, o usar técnicas de cold-boot attack sobre la memoria RAM.
- **Arranque desde medios externos:** Conectar un USB booteable con un sistema operativo Live (como Kali Linux) para bypassar el sistema operativo instalado y acceder a

los datos en disco.

- **Keylogger físico:** Conectar un pequeño dispositivo entre el teclado y la PC para capturar todas las contraseñas.
- **Destrucción o sabotaje:** Simplemente desconectar los cables de red, cortar la energía o destruir el equipo.

Pregunta 2: Modelo de cebolla (perímetros)

Respuesta

El **modelo de cebolla** es una estrategia de defensa en profundidad donde la seguridad se implementa en anillos concéntricos. Cada anillo es una barrera que obliga al atacante a superar un control adicional. Tres anillos posibles (de afuera hacia adentro):

1. **Anillo del predio:** Cercos perimetrales, iluminación, CCTV, guardias en la entrada principal.
2. **Anillo del edificio:** Recepción con control de visitantes, molinetes con tarjeta RFID, exclusión de accesos no autorizados.
3. **Anillo de la sala de servidores:** Puerta blindada, acceso biométrico (huella o iris), esclusa de seguridad (mantrap) para evitar el tailgating.

Pregunta 3: Incendios en Data Centers

Respuesta

No se usan rociadores de agua porque el agua **destruiría los servidores y cortocircuitaría el hardware**, causando tanto o más daño que el fuego mismo (pérdida total de la Disponibilidad e Integridad). La alternativa es el uso de **sistemas de extinción por gases limpios** (ej. FM-200, Novec 1230 o Inergen). Estos gases apagan el fuego en segundos absorbiendo el calor o inhibiendo la reacción química de la combustión, **sin dejar residuos, sin ser conductores de electricidad y sin dañar los equipos electrónicos**.

Pregunta 4: Tailgating vs. Piggybacking

Respuesta

- **Tailgating (Pisar los talones):** El atacante entra sin que la víctima se dé cuenta, pegado a su espalda antes de que la puerta se cierre. Es un acto **no consentido**.
- **Piggybacking (Llevar a cuestas):** La víctima **consiente y coopera** (aunque engañada), por ejemplo, sosteniendo la puerta abierta al atacante porque este trae las manos ocupadas o dice haber olvidado la tarjeta.

El **Piggybacking** es más difícil de mitigar con tecnología, porque explota la **cortesía humana** y la empatía. Requiere concientización constante y una cultura de seguridad donde «no sostener la puerta» no sea visto como una grosería, sino como un procedimiento.

Pregunta 5: Dumpster Diving y mitigación

Respuesta

El **Dumpster Diving** es la técnica de revisar la basura de una organización en busca de información sensible: documentos impresos sin destruir, notas con contraseñas, organigramas, discos o pendrives desechados sin formatear. La política administrativa fundamental para mitigarlo es la **Política de Escritorio Limpio y de Desecho Seguro**, que obliga a:

- Triturar (shredding) todo documento confidencial antes de desecharlo.
- Destruir físicamente o degaussar los medios magnéticos antes de tirarlos.
- Disponer de contenedores cerrados con llave para material sensible, que solo sean retirados por empresas de destrucción certificada.

9. Actividad A05: Desafío de Ingeniería Social

¡Atención! Límites éticos y legales

La Ingeniería Social es una técnica ofensiva. Su uso sin autorización constituye un **delito** según la legislación vigente. Para esta actividad académica, **todo objetivo debe tener consentimiento** o ser un entorno simulado controlado por la cátedra. Nunca intentes estas técnicas sobre personas o instituciones no autorizadas.

Consigna A05 — Seguridad Física e Ingeniería Social

Objetivo: Comprender en la práctica cómo el factor humano es el eslabón más débil de la seguridad física.

Tarea: Realizar un ejercicio controlado de Ingeniería Social con el fin de «obtener información confidencial o importante» que comprometa la seguridad física de un entorno.

Opciones de ejercicio (elegir una):

1. **Conocido consentido:** Pedirle a un amigo o familiar (que sepa que estás haciendo la tarea) que te dé por teléfono o chat información sensible (ej. nombre de su proveedor de internet, número de cuenta, modelo de router, horarios en que no está en casa) usando pretextos creativos.
2. **OSINT Físico (Dumpster Diving simulado):** Analizar la huella física pública de una empresa (fotos de sus empleados en redes sociales donde se ven credenciales, monitores o fondos; horarios de ingreso por LinkedIn; direcciones de sucursales).
3. **Simulación de Pretexting:** Llamar a un servicio de atención al cliente (del cual seas cliente) y ver cuánta información pueden darte si simulás haber perdido tus datos, sin dar más que información básica.

Entregable: Un informe donde detallas:

- La técnica utilizada (Pretexting, OSINT, Vishing, etc.).
- El escenario montado.
- La información «confidencial» obtenida.

- Una reflexión ética y las **salvaguardas administrativas** (capacitación, políticas) que hubieran evitado el éxito de tu ataque.

Subilo a la carpeta del Trabajo Integrador en Google Drive, otorgando permisos de comentario a era.profe@gmail.com.

Rúbrica de evaluación (según grilla de la cátedra):

Criterio	Peso	Qué se espera para el «Excelente» (4)
A. Recopilación de información	50 %	Utiliza de manera completa fuentes confiables (marcos de ingeniería social, libros de Mitnick, etc.) y las cita correctamente.
B. Elaboración de documentos	20 %	Cumple adecuadamente con los formatos atento a la planilla de estandarización brindada por la cátedra.
C. Elaboración de presentaciones	10 %	Argumenta de manera sólida el escenario, la técnica utilizada y cómo se hubiera mitigado.
F. Consciencia de buenas prácticas	20 %	Evidencia permanentemente el respeto por los límites éticos y legales en la ejecución del ejercicio.

10. Fuentes y bibliografía

10.1. Bibliografía obligatoria (según programa)

- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- Elgueta, R. (s.f.). *Guías de Clase unidad III*. Material inédito. UCH.

10.2. Bibliografía complementaria (según programa)

- Bancal, D. (2022). *Seguridad informática* (5.^a ed.). Ediciones ENI.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing to Audit and Improve the Cybersecurity of Computer Networks for Beginners, Including Tips on Social Engineering*. Amazon Digital Services LLC — KDP.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace Independent Publishing Platform.
- Mitnick, K. & Simon, W. (2002). *The Art of Deception: Controlling the Human Element of Security*. Wiley.
- Hadnagy, C. (2018). *Social Engineering: The Science of Human Hacking* (2.^a ed.). Wiley.
- ISO/IEC (2005). *Information security management 27001* (Anexo A.9 y A.11 sobre seguridad física).

10.3. Recursos web y normativas

- Portales CERT, NIST, Hispasec.
- Norma TIA-942 (estándar de infraestructura para Data Centers).
- Material audiovisual: Documental *The Weakest Link* (sobre Ingeniería Social).